

Linux基线加固

作者：未知

原文链接：<https://mp.weixin.qq.com/s/0nxiZw1NUoQTjxcd3zl6Zg>

本文由 干货集中营 收集整理：<http://www.nmd5.com/test/index.php>

主机安全的风险级别除了漏洞，另一个重要的参考值是安全基线的风险分值，本次介绍的主要是结合目前公司的业务实际情况制作的一份安全基线脚本，供大家进行参考。

适用环境

适用环境：RedHat系统Linux

注意

在配置系统基线测试之前，虚拟机一定要提前制作快照，配置测试期间尽量不要退出登录状态，以便出现差错的时候能够及时回退。

基线配置内容

/etc/pam.d/system-auth

是用户使用pam认证模块的登录策略配置文件，配置用户密码的复杂度、登录失败暂锁、重复使用密码次数等都是配置此文件。

密码复杂度是在password验证类型中调用pam_cracklib.so动态链接库：

```
password    required    pam_cracklib.so try_first_pass minlen=8 ucredit=-1 lcredit=-1 ocredit=-1 dcredit=-1 retry=3 difok=5
```

```
#设置密码复杂度
if [ -z "$(cat /etc/pam.d/system-auth | grep -v "^#" | grep "pam_cracklib.so")" ];then
    sed -i '/password    required    pam_deny.so/a\password    required    pam_cracklib.so try_first_pass minlen=8 ucredit=-1 lcredit=-1 ocredit=-1 dcredit=-1 retry=3 difok=5' /etc/pam.d/system-auth
fi
```

登录失败暂锁机制是在auth和account验证类型中调用pam_tally.so动态链接库，此外，针对远程登录的设置可在/etc/pam.d/sshd配置文件中做同样的配置：

```
auth        required    pam_tally.so deny=5 unlock_time=600 even_deny_root root_unlock_time=600
account     required    pam_tally.so
```

```
#设置连续登录失败解锁机制
if [ -z "`cat /etc/pam.d/system-auth | grep -v "^#" | grep "pam_tally.so"`" ];then
    if [ -z "`cat /etc/pam.d/system-auth | grep -v "^#" | grep "pam_tally.so" | grep
    auth`" ];then
        sed -i '/auth        include        system-auth/a\auth        required
pam_tally.so deny=5 unlock_time=600 even_deny_root root_unlock_time=600' /etc/pam.d/syst
em-auth
    fi
    if [ -z "`cat /etc/pam.d/system-auth | grep -v "^#" | grep "pam_tally.so" | grep
account`" ];
    then
        sed -i '/account    include        system-auth/a\account    required
pam_tally.so' /etc/pam.d/system-auth
    fi
fi

if [ -z "`cat /etc/pam.d/sshd | grep -v "^#" | grep "pam_tally.so"`" ];then
    if [ -z "`cat /etc/pam.d/sshd | grep -v "^#" | grep "pam_tally.so" | grep auth`"
    ];then
        sed -i '/auth        required        pam_deny.so/a\auth        required
pam_tally.so deny=5 unlock_time=600 even_deny_root root_unlock_time=600' /etc/pam.d/s
shd
    fi
    if [ -z "`cat /etc/pam.d/sshd | grep -v "^#" | grep "pam_tally.so`" | grep accou
nt`" ];then
        sed -i '/account    required        pam_unix.so/a\account required pam_ta
lly.so' /etc/pam.d/sshd
    fi
fi
```

密码重复使用次数在password验证类型调用pam_unix.so链接库：

```
password    sufficient    pam_unix.so remember=5
```

```
#检查密码重复使用次数
if [ -z "`cat /etc/pam.d/system-auth | grep password | grep remember`" ];then
    sed -i '/password    sufficient    pam_unix.so/s/$/& remember=5/' /etc/pam.d/sys
tem-auth
fi
```

设置登录超时退出机制需要在/etc/profile文件中添加TMOUT值的设置：

```
#设置操作超时锁定
if [ -z "`cat /etc/profile | grep -v "^#" | grep TMOUT`" ];then
    echo -e "\nexport TMOUT=1800" >> /etc/profile
fi
```

/etc/login.defs

文件是配置用户密码策略的，基线检查项中包括密码的时效性及默认访问权限两项。

密码时效性按照要求需满足最小长度8位、最大使用时间90天、最小使用天数6天、提醒时间为30天，也可根据实际需求自定义：

```
#修改密码时效
sed -i '/PASS_WARN_AGE/s/7/10/' /etc/login.defs
sed -i '/PASS_MIN_LEN/s/5/8/' /etc/login.defs
#sed -i '/PASS_MAX_DAYS/s/99999/90/' /etc/login.defs
sed -i '/PASS_MIN_DAYS/s/0/6/' /etc/login.defs
```

默认访问权限修改：

```
#修改默认访问权限
sed -i '/UMASK/s/077/027/' /etc/login.defs
```

对重要文件目录权限的设置：

```
#设置重要文件目录权限
chmod 644 /etc/passwd
chmod 600 /etc/xinetd.conf
chmod 600 /etc/inetd.conf
chmod 644 /etc/group
chmod 000 /etc/shadow
chmod 644 /etc/services
chmod 600 /etc/security
chmod 750 /etc/
#启动了nscd服务导致设置权限以后无法登陆
chmod 750 /etc/rc6.d
chmod 750 /tmp
chmod 750 /etc/rc0.d/
chmod 750 /etc/rc1.d/
chmod 750 /etc/rc2.d/
chmod 750 /etc/rc4.d
chmod 750 /etc/rc5.d/
chmod 750 /etc/rc3.d
chmod 750 /etc/rc.d/init.d/
chmod 600 /etc/grub.conf
chmod 600 /boot/grub/grub.conf
chmod 600 /etc/lilo.conf
```

在这里遇到了一个最大的坑，在修改/etc目录的权限后，导致了系统无法登陆，之后查看应用日志才发现，系统启用了nscd服务的原因，具体原因无法确定，但是根据nscd服务的作用是缓存passwd、group、hosts三种服务加快解析，可能原因是用户登录时认证先通过nscd服务缓存，但是nscd服务进程因权限设置无法读取/etc/group和/etc/passwd导致。

登录时提示connect reset by peer是/etc/ssh/下的key文件权限过大导致：

```
[root@ansible ~]# chmod 750 /etc
[root@ansible ~]# ssh 127.0.0.1
ssh_exchange_identification: read: Connection reset by peer
[root@ansible ~]# chmod 0600 /etc/ssh/ssh_host_rsa_key /etc/ssh/ssh_host_ecdsa_key /etc/ssh/ssh_host_ed25519_key /etc/ssh/ssh_host_dsa_key
```

提示No user exists for uid 0，则是nscd服务进程无法读取/etc/passwd文件的原因，关闭nscd服务并禁止自启动则行：

```
[root@ansible ~]# ssh 127.0.0.1
No user exists for uid
```

```
[root@ansible ~]# tail -3f /var/log/messages
Jul 19 10:54:37 ansible nscd: 1683 checking for monitored file '/etc/group': Permission denied
Jul 19 10:54:55 ansible nscd: 1683 checking for monitored file '/etc/passwd': Permission denied
Jul 19 10:55:10 ansible nscd: 1683 checking for monitored file '/etc/passwd': Permission denied
Jul 19 10:55:56 ansible nscd: 1683 checking for monitored file '/etc/passwd': Permission denied
Jul 19 10:56:11 ansible nscd: 1683 checking for monitored file '/etc/passwd': Permission denied
```

```
[root@ansible /]# chkconfig --list |grep nscd
nscd          0:off  1:off  2:on   3:on   4:on   5:on   6:off
```

```
[root@ansible /]# chkconfig --del nscd
[root@ansible /]# chkconfig --list |grep nscd
[root@ansible /]# id root
uid=0(root) gid=0(root) groups=0(root)
```

设置用户umask为077:

```
#检查用户umask设置
sed -i '/umask/s/002/077/' /etc/csh.cshrc
sed -i '/umask/s/002/077/' /etc/bashrc
sed -i '/umask/s/002/077/' /etc/profile
csh_login=$(cat /etc/csh.login | grep -i "umask")
if [ -z "$csh_login" ];then
    echo -e "/umask 077" >> /etc/csh.login
fi
```

ssh登录设置告警banner

```
#检查是否设置ssh登录前告警banner
sshbanner="/etc/ssh_banner"
if [ ! -f "$sshbanner" ];then
    touch /etc/ssh_banner
    chown bin:bin /etc/ssh_banner
    chmod 644 /etc/ssh_banner
    echo -e "Authorized only.All activity will be monitored and reported" > /etc/ssh_banner
    echo -e "Banner /etc/ssh_banner" >> /etc/ssh/sshd_config
    /etc/init.d/sshd restart
fi
```

FTP安全设置，禁止匿名登录、禁止root登录、删除ftp账户登录系统

```
#FTP安全设置
vsftpd_conf=`find /etc/ -maxdepth 2 -name vsftpd.conf`
if [ ! -z "$vsftpd_conf" ];then
    sed -i '/anonymous_enable/s/YES/NO/' $vsftpd_conf
fi

ftpuser=`find /etc/ -maxdepth 2 -name ftpusers`
if [ ! -z "$ftpuser" ] && [ -z "`cat $ftpuser | grep -v "^#" | grep root`" ];then
    echo "root" >>$ftpuser
fi

sed -i '/^ftp/d' /etc/passwd
```

信安之路

设置重要的文件属性放篡改:

```
#检查重要文件属性设置
chattr +i /etc/passwd
chattr +i /etc/shadow
chattr +i /etc/group
chattr +i /etc/gshadow
```

信安之路

设置日志审计检查:

首先需要安装syslog或者rsyslog或者syslog-ng三个服务中的一个, 然后需要保证创建了/var/log/cron、/var/adm/messages文件。

在/etc/rsyslog.conf或/etc/syslog.conf配置文件中添加:

```
echo -e "filter f_cron { facility(cron) or facility(auth) }" >> /etc/rsyslog.conf
echo -e "destination cron { file(\"/var/log/cron\") }" >> /etc/rsyslog.conf
echo -e "log { source(src); filter(f_cron); }" >> /etc/rsyslog.conf

echo -e "filter f_msgs { level(err) or facility(auth) }" >> /etc/rsyslog.conf
echo -e "destination msgs { file(\"/var/adm/messages\") }" >> /etc/rsyslog.conf
echo -e "log { source(src); filter(f_msgs); }" >> /etc/rsyslog.conf

echo -e "destination logserver { udp(\"192.168.0.1:514\") }" >> /etc/rsyslog.conf
echo -e "log { source(src); destination(logserver); }" >> /etc/rsyslog.conf
```

在/etc/syslog-ng/syslog-ng.conf配置文件中添加:

```
echo -e "cron.* /var/log/cron" >> /etc/rsyslog.conf
echo -e "/*.err;kern.debug;daemon.notice /var/adm/messages" >> /etc/rsyslog.conf
echo -e " *.* @192.168.0.1" >> /etc/rsyslog.conf #192.168.0.1替换为远程日志服务器ip
```

信安之路

禁止wheel组以外的用户su为root, 在/etc/pam.d/su文件内开头添加:

```
auth      sufficient    pam_rootok.so
auth      required      pam_wheel.so group=wheel
```

```
#禁止wheel组以外的用户su为root
if [ -z "`cat /etc/pam.d/su | grep -v "^#" | grep pam_wheel.so`" ];then
    if [ -z "`cat /etc/pam.d/su | grep -v "^#" | grep pam_rootok.so`" ];then
        sed -i '2i auth      sufficient    pam_rootok.so' /etc/pam.d/su
        sed -i '/pam_rootok.so/a auth      required      pam_wheel.so gr
oup=wheel' /etc/pam.d/su
    else
        sed -i '/pam_rootok.so/a auth      required      pam_wheel.so gr
oup=wheel' /etc/pam.d/su
    fi
fi
```

关闭不必要的服务与端口:

ntalk、lpd、kshell、time、sendmail、klogin、printer、nfslock、echo、discard、chargen、bootps、daytime、tftp、ypbind、ident

设置core dump

```
#检查core dump 设置
chk_core=`grep core /etc/security/limits.conf | grep -v "^#"`
if [ -z "$chk_core" ];then
    echo "*                soft    core            0" >> /etc/security/limits.conf
    echo "*                hard    core            0" >> /etc/security/limits.conf
fi
```

删除潜在危险文件hosts.equiv、.rhosts、.netrc

```
#删除潜在危险文件
hosts_equiv=`find / -maxdepth 3 -name hosts.equiv 2>/dev/null`
if [ ! -z "$hosts_equiv" ];then
    mv "$hosts_equiv" "$hosts_equiv".bak
fi

_rhosts=`find / -maxdepth 3 -name .rhosts 2>/dev/null`
if [ ! -z "$_rhosts" ];then
    mv "$_rhosts" "$_rhosts".bak
fi

_netrc=`find / -maxdepth 3 -name .netrc 2>/dev/null`
if [ ! -z "$_netrc" ];then
    mv "$_netrc" "$_netrc".bak
fi
```

设置系统的内核参数:

```
#检查系统内核参数配置,修改只当次生效,重启需重新设置
sysctl -w net.ipv4.conf.all.accept_source_route="0"
sysctl -w net.ipv4.conf.all.accept_redirects="0"
sysctl -w net.ipv4.icmp_echo_ignore_broadcasts="1"
sysctl -w net.ipv4.conf.all.send_redirects="0"
sysctl -w net.ipv4.ip_forward="0" 信安之路
```

检查修改suid和sgid权限文件:

```
#检查拥有suid和sgid权限文件并修改文件权限为755
find /usr/bin/chage /usr/bin/gpasswd /usr/bin/wall /usr/bin/chfn /usr/bin/chsh /usr/bin/
newgrp /usr/bin/write /usr/sbin/usernetctl /bin/mount /bin/umount /bin/pin 信安之路
ort -type f -perm /6000 | xargs chmod 755
```

加固脚本:

306 lines (249 sloc) | 9.78 KB

```
1  #!/bin/bash
2
3  #设置密码复杂度
4  if [ -z "`cat /etc/pam.d/system-auth |
5      sed -i '/password      required
6  fi
7
8
9  #设置连续登录失败暂锁机制
10 if [ -z "`cat /etc/pam.d/system-auth |
11     if [ -z "`cat /etc/pam.d/syste
12         sed -i '/auth      inc
13     fi
14     if [ -z "`cat /etc/pam.d/syste
15     then
16         sed -i '/account    in
17     fi
18 fi
19
20 if [ -z "`cat /etc/pam.d/sshd | grep -
21     if [ -z "`cat /etc/pam.d/sshd
22         sed -i '/auth      r
23     fi
24     if [ -z "`cat /etc/pam.d/sshd
25         sed -i '/account    r
26     fi
27 fi
28
29
30 #检查密码重复使用次数
31 if [ -z "`cat /etc/pam.d/system-auth |
```

请大家点击原文连接获取加固脚本完整版。

